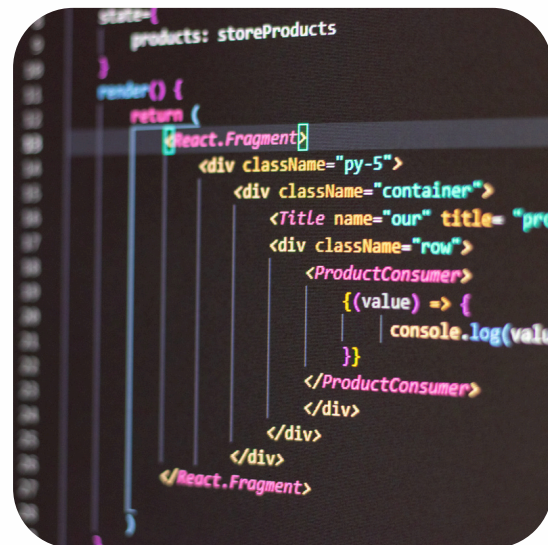


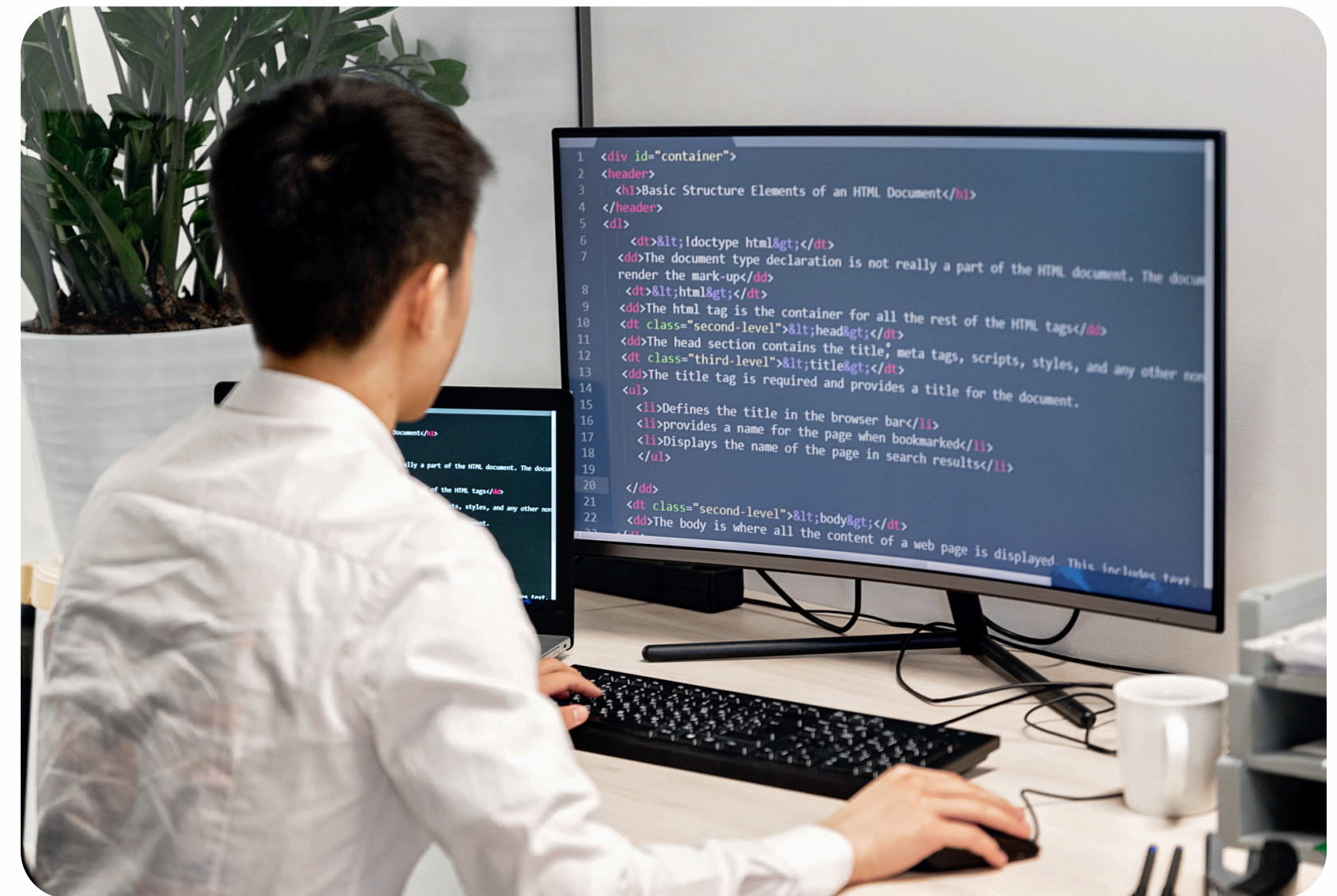
CIBERSEGURIDAD EN PYTHON

GESTIÓN DE DEPENDENCIAS

- **DESCRIPCIÓN:** CONSISTE EN CONTROLAR, REGISTRAR Y REVISAR MINUCIOSAMENTE LAS LIBRERÍAS EXTERNAS QUE SE AÑADEN A UN PROYECTO. UTILIZAR HERRAMIENTAS PARA CONGELAR LAS VERSIONES EVITA QUE SE INSTALEN PAQUETES MALICIOSOS O IMPREVISTOS.



- **EJEMPLO:** USAR UN ARCHIVO REQUIREMENTS.TXT GENERADO CON PIP FREEZE > REQUIREMENTS.TXT O HERRAMIENTAS COMO PIPENV Y POETRY PARA ASEGURAR QUE TODO EL EQUIPO USE EXACTAMENTE LAS MISMAS VERSIONES PROBADAS.



DIGITAL EVOLUTION



- **DESCRIPCIÓN:** ES LA PRÁCTICA DE NUNCA ESCRIBIR CONTRASEÑAS, TOKENS DE API, CLAVES DE BASES DE DATOS O LLAVES CRIPTOGRÁFICAS DIRECTAMENTE EN EL CÓDIGO FUENTE (HARDCODING), YA QUE PODRÍAN FILTRARSE EN REPOSITORIOS PÚBLICOS COMO GITHUB.
- **EJEMPLO:** ALMACENAR LAS CREDENCIALES EN UN ARCHIVO .ENV EXTERNO Y OCULTO, Y CARGARLAS EN PYTHON USANDO LA LIBRERÍA PYTHON-DOTENV

```
import os
from dotenv import load_env
load_env()
db_password = os.getenv("db_password")
```





- **DESCRIPCIÓN:** PROCESO DE VERIFICAR QUE TODOS LOS DATOS INTRODUCIDOS POR UN USUARIO (EN FORMULARIOS, URLS O APIS) CUMPLAN EstrictAMENTE CON LAS REGLAS DEL SISTEMA (TIPO DE DATO, LONGITUD, FORMATO) ANTES DE SER PROCESADOS.
- **EJEMPLO:** SI UN SISTEMA PIDE UNA EDAD, VALIDAR CON LIBRERÍAS COMO PYDANTIC O MEDIANTE CÓDIGO QUE SEA UN NÚMERO ENTERO POSITIVO MAYOR A CERO Y MENOR A 120, RECHAZANDO CUALQUIER TEXTO O SÍMBOLO EXTRAÑO.

- **DESCRIPCIÓN:** A DIFERENCIA DE LA VALIDACIÓN, EL SANEAMIENTO MODIFICA LA ENTRADA DEL USUARIO PARA LIMPIAR O ELIMINAR CARACTERES POTENCIALMENTE PELIGROSOS (COMO ETIQUETAS HTML O SCRIPTS EJECUTABLES) ANTES DE RENDERIZARLOS O GUARDARLOS.
- **EJEMPLO:** UTILIZAR LA LIBRERÍA BLEACH EN PYTHON PARA LIMPIAR UN COMENTARIO DE UN BLOG, TRANSFORMANDO UN TEXTO PELIGROSO COMO `<SCRIPT>MALICIOSO</SCRIPT>` EN TEXTO PLANO INOFENSIVO.



VALIDACIÓN DE ENTRADAS Y SANEAMIENTO DE DATOS

```
status = Status(  
    status_id=data.id, name=data.name,  
)  
statuses[status.name] = status
```


PRINCIPIO DE MENOR PRIVILEGIO Y ACTUALIZACIÓN DEL ENTORNO

- **DESCRIPCIÓN:** REGLA DE SEGURIDAD INFORMÁTICA QUE ESTABLECE QUE LOS USUARIOS, PROCESOS O SCRIPTS DE PYTHON DEBEN TENER ÚNICAMENTE LOS PERMISOS Estrictamente necesarios para realizar su función, y ninguno más.
- **EJEMPLO:** CONFIGURAR EL SCRIPT DE PYTHON QUE RESPALDA LA BASE DE DATOS PARA QUE USE UN USUARIO DE BASE DE DATOS CON PERMISOS EXCLUSIVOS DE "LECTURA" (SELECT), IMPIDIENDO POR COMPLETO QUE ESE SCRIPT PUEDA BORRAR O MODIFICAR TABLAS.



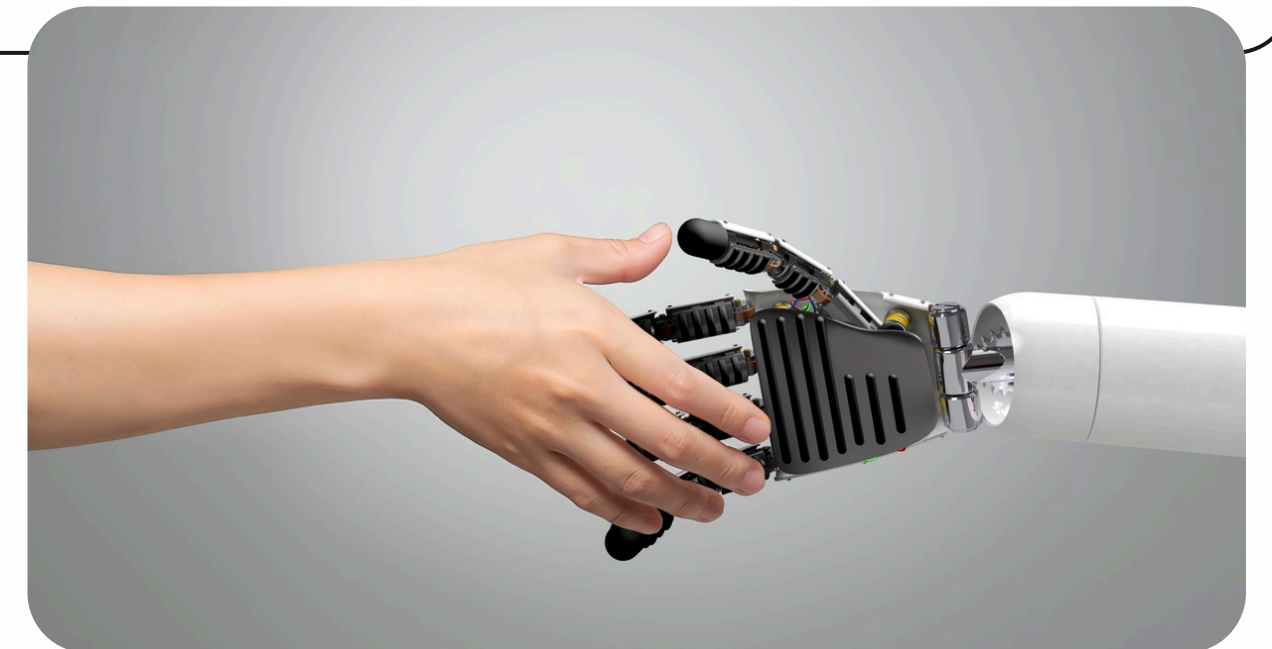
- **DESCRIPCIÓN:** MANTENER LA VERSIÓN DEL INTÉRPRETE DE PYTHON, EL SISTEMA OPERATIVO Y TODAS LAS DEPENDENCIAS DEL PROYECTO ACTUALIZADAS CON LOS ÚLTIMOS PARCHES DE SEGURIDAD PARA MITIGAR VULNERABILIDADES CONOCIDAS.
- **EJEMPLO:** PROGRAMAR AUDITORÍAS PERIÓDICAS EJECUTANDO EL COMANDO PIP AUDIT EN LA TERMINAL PARA ESCANEAR EL ENTORNO LOCAL EN BUSCA DE LIBRERÍAS DESACTUALIZADAS CON FALLOS DE SEGURIDAD REPORTADOS.

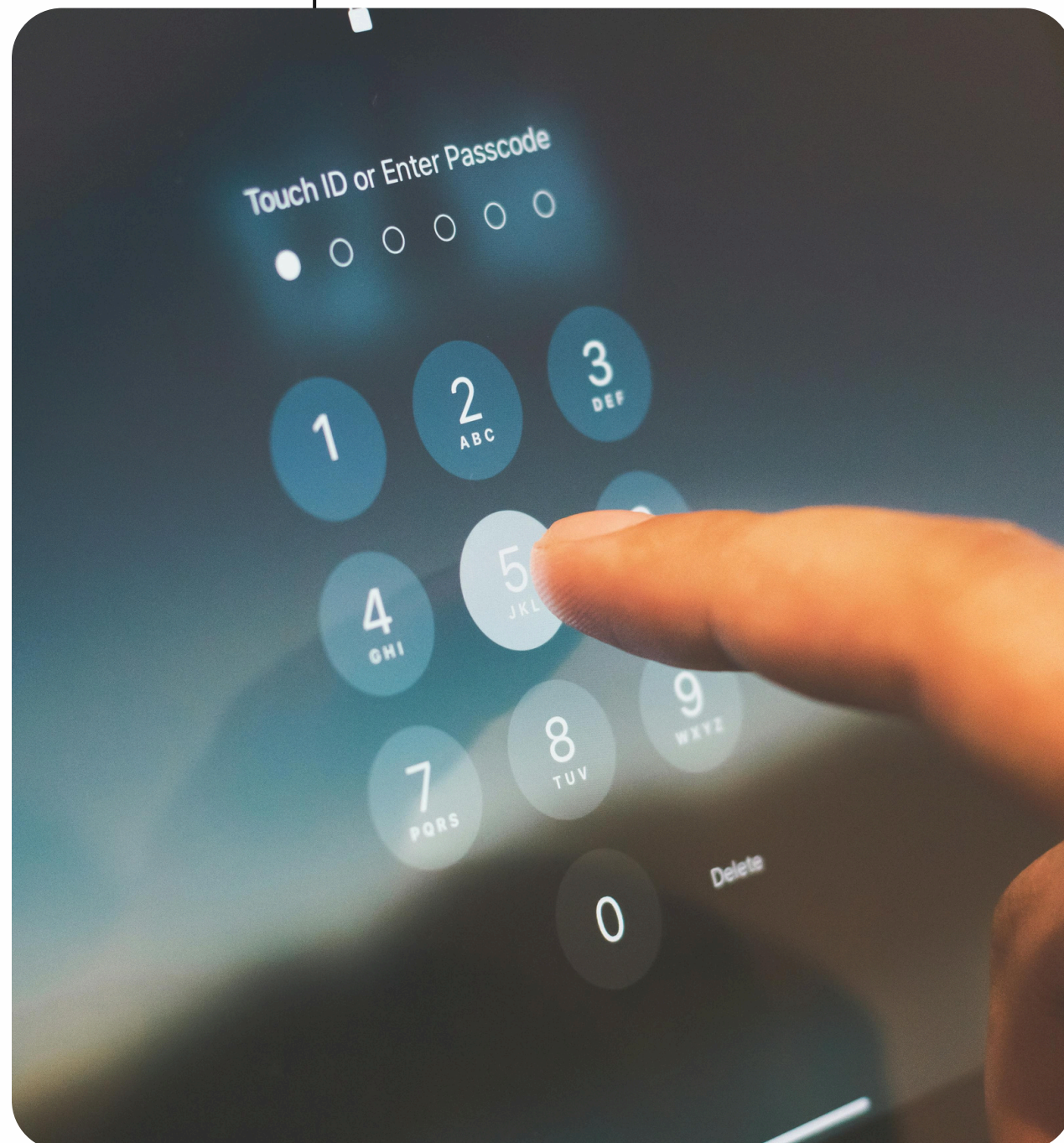


- **DESCRIPCIÓN:** OCURRE CUANDO UN ATACANTE LOGRA QUE EL INTÉRPRETE DE PYTHON EJECUTE CÓDIGO ARBITRARIO MALICIOSO DEBIDO AL USO INSEGURO DE FUNCIONES INTEGRADAS QUE EVALÚAN STRINGS COMO COMANDOS VIVOS.
- **EJEMPLO:** SI UN PROGRAMA USA `EVAL(INPUT())` PARA UNA CALCULADORA Y UN USUARIO ESCRIBE `__IMPORT__('OS').SYSTEM('RM -RF /')`, EL PROGRAMA BORRARÁ LOS ARCHIVOS DEL SISTEMA OPERATIVO EN LUGAR DE HACER UNA OPERACIÓN MATEMÁTICA.

- **DESCRIPCIÓN:** SUCEDE CUANDO LOS DATOS INGRESADOS POR EL USUARIO SE CONCATENAN DIRECTAMENTE DENTRO DE UNA CONSULTA DE BASE DE DATOS, PERMITIENDO AL ATACANTE MANIPULAR LA ESTRUCTURA DE LA CONSULTA PARA ROBAR O DESTRUIR INFORMACIÓN.
- **EJEMPLO:**
- **INSEGURO:** `CURSOR.EXECUTE(F"SELECT * FROM USERS WHERE USER = '{USUARIO_WEB}'")`
- SI EL ATACANTE ESCRIBE `' OR '1'='1`, LA CONSULTA DEVOLVERÁ TODOS LOS USUARIOS DEL SISTEMA.

INYECCIÓN DE CÓDIGO (`EVAL()`/`EXEC()`) Y INYECCIÓN SQL





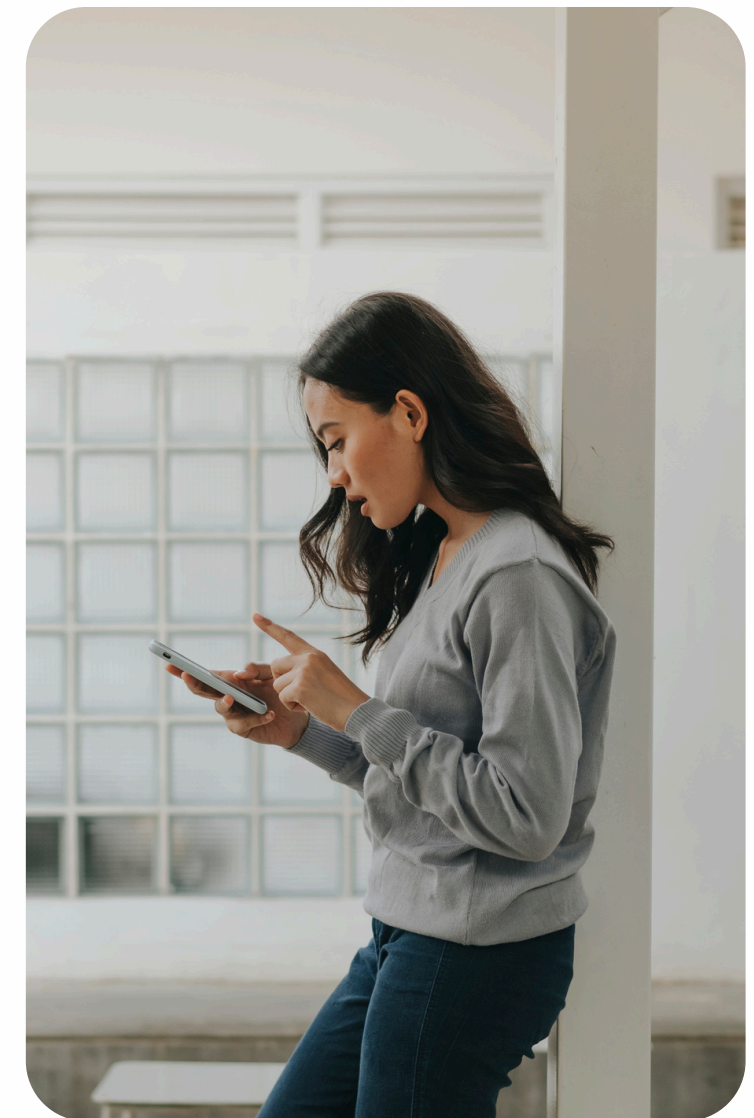
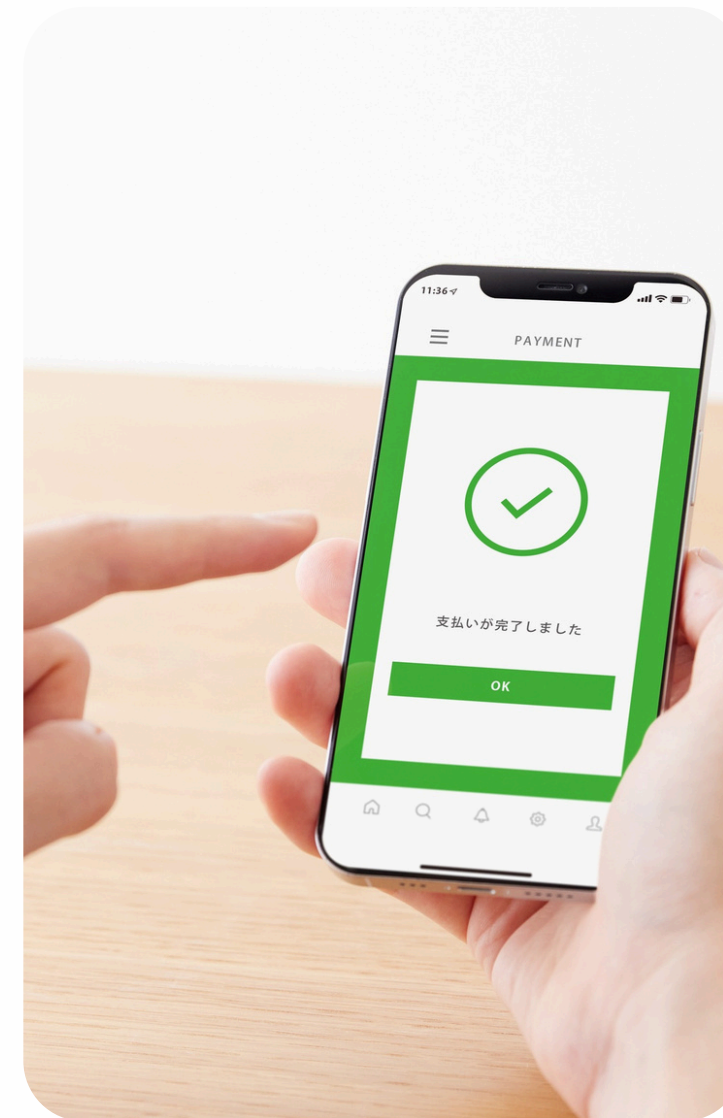
- **DESCRIPCIÓN:** LA LIBRERÍA PICKLE EN PYTHON CONVIERTE OBJETOS EN CADENAS DE BYTES PARA GUARDARLOS O TRANSMITIRLOS. SI SE DESERIALIZA (RECONSTRUYE) UN ARCHIVO PICKLE MODIFICADO POR UN ATACANTE, ESTE PUEDE EJECUTAR COMANDOS AUTOMÁTICAMENTE AL ABRIRSE.
- **EJEMPLO:** RECIBIR UN ARCHIVO DE CONFIGURACIÓN .PKL DE UN USUARIO DESCONOCIDO Y EJECUTAR `PICKLE.LOADS(DATOS)`. SI EL ARCHIVO FUE ALTERADO, PUEDE TOMAR EL CONTROL DEL SERVIDOR INSTANTÁNEAMENTE.

- **DESCRIPCIÓN:** EXPLOTACIÓN DE UNA VULNERABILIDAD EN UN PAQUETE DE PYTHON QUE ACABA DE SER DESCUBIERTA Y PARA LA CUAL EL DESARROLLADOR ORIGINAL AÚN NO HA LANZADO NINGÚN PARCHO O ACTUALIZACIÓN DE SEGURIDAD.
- **EJEMPLO:** UN GRUPO DE HACKERS DESCUBRE UN FALLO CRÍTICO EN UNA LIBRERÍA POPULAR DE PROCESAMIENTO DE IMÁGENES Y LA EXPLOTA EN SERVIDORES DE TODO EL MUNDO ANTES DE QUE LA COMUNIDAD SE DÉ CUENTA Y CREE UNA SOLUCIÓN.

DESERIALIZACIÓN INSEGURA Y ATAQUES DE DÍA CERO EN LIBRERÍAS

SECUESTRO DE TIPOGRAFÍA Y INYECCIÓN DE COMANDOS

- **DESCRIPCIÓN:** TÉCNICA DONDE LOS ATACANTES SUBEN PAQUETES MALICIOSOS AL REPOSITORIO OFICIAL PYPI USANDO NOMBRES MUY SIMILARES A LIBRERÍAS POPULARES, ESPERANDO QUE LOS DESARROLLADORES COMETAN UN ERROR DE DEDO AL ESCRIBIR EL COMANDO DE INSTALACIÓN.
 - **EJEMPLO:** INSTALAR POR ERROR PIP INSTALL REQEUSTS (CON UN ERROR TIPOGRÁFICO) EN LUGAR DE LA LIBRERÍA LEGÍTIMA PIP INSTALL REQUESTS. EL PAQUETE FALSO FUNCIONA IGUAL, PERO ROBA TUS DATOS EN SEGUNDO PLANO.
-
- **DESCRIPCIÓN:** VULNERABILIDAD QUE PERMITE A UN ATACANTE EJECUTAR COMANDOS DEL SISTEMA OPERATIVO (BASH O CMD) A TRAVÉS DE UNA APLICACIÓN DE PYTHON QUE INTERACTÚA DE MANERA INSEGURA CON LA CONSOLA.
 - **EJEMPLO:** UN SCRIPT QUE USA `OS.SYSTEM(F"PING {IP_USUARIO}")`. SI EL USUARIO INGRESA `8.8.8.8 ; CAT /ETC/PASSWD`, EL SERVIDOR EJECUTARÁ EL PING Y LUEGO EXPONDRÁ EL ARCHIVO CON LOS USUARIOS DEL SISTEMA.



Phishing tradicional

- **DESCRIPCIÓN:** ES EL CONJUNTO DE TÉCNICAS DE MANIPULACIÓN PSICOLÓGICA UTILIZADAS POR LOS CIBERCRIMINALES PARA ENGAÑAR A LAS PERSONAS Y LOGRAR QUE REALICEN ACCIONES VOLUNTARIAS INVOLUNTARIAS, COMO REVELAR INFORMACIÓN CONFIDENCIAL O DAR ACCESO A SISTEMAS DE SEGURIDAD.
- **OBJETIVO:** EL ESLABÓN MÁS DÉBIL EN LA SEGURIDAD SUELE SER EL SER HUMANO. EL OBJETIVO PRINCIPAL ES BURLAR LOS CONTROLES TECNOLÓGICOS EXPLOTANDO RASGOS HUMANOS COMO LA CONFIANZA, EL MIEDO, LA URGENCIA, LA VANIDAD O LA CURIOSIDAD.

- **DESCRIPCIÓN:** ENVÍO MASIVO E INDISCRIMINADO DE CORREOS ELECTRÓNICOS FALSOS QUE IMITAN A EMPRESAS E INSTITUCIONES LEGÍTIMAS (BANCOS, REDES SOCIALES) CON ENLACES A PÁGINAS WEB CLONADAS PARA ROBAR CREDENCIALES.
- **EJEMPLO:** UN CORREO MASIVO CON EL LOGO DE NETFLIX QUE DICE: "SU CUENTA HA SIDO SUSPENDIDA POR FALTA DE PAGO, HAGA CLIC AQUÍ PARA ACTUALIZAR SU TARJETA DE CRÉDITO".



**¿QUÉ ES LA INGENIERÍA SOCIAL
Y CUÁL ES SU OBJETIVO?**

Spear Phishing

y

Whaling

- **DESCRIPCIÓN:** UN ATAQUE DE PHISHING ALTAMENTE PERSONALIZADO Y DIRIGIDO ESPECÍFICAMENTE A UN INDIVIDUO O EMPRESA EN PARTICULAR. REQUIERE INVESTIGACIÓN PREVIA SOBRE LA VÍCTIMA PARA HACER EL ENGAÑO MUY CREÍBLE.
- **EJEMPLO:** UN CORREO DIRIGIDO A UN CONTADOR QUE DICE: "HOLA CARLOS, TE ADJUNTO LA FACTURA PENDIENTE DEL PROYECTO DE REMODELACIÓN DE LA OFICINA DE LA SEMANA PASADA", SABIENDO QUE ESA REMODELACIÓN REALMENTE OCURRIÓ.



- **DESCRIPCIÓN:** ES UNA VARIANTE DE SPEAR PHISHING DIRIGIDA EXCLUSIVAMENTE A PERFILES DE ALTO VALOR DENTRO DE UNA ORGANIZACIÓN, COMO DIRECTORES EJECUTIVOS (CEOS), PRESIDENTES O ALTOS EJECUTIVOS FINANCIEROS, BUSCANDO FRAUDES MILLONARIOS.
- **EJEMPLO:** UN CORREO FALSO ENVIADO AL DIRECTOR DE FINANZAS, SUPUESTAMENTE REMITIDO POR EL CEO DEL CORPORATIVO, EXIGIENDO UNA TRANSFERENCIA ELECTRÓNICA CONFIDENCIAL Y URGENTE PARA CERRAR UNA ADQUISICIÓN SECRETA.

SMISHING Y



- **DESCRIPCIÓN:** ATAQUE DE SUPLANTACIÓN DE IDENTIDAD QUE UTILIZA MENSAJES DE TEXTO DE TELEFONÍA MÓVIL (SMS) O APLICACIONES DE MENSAJERÍA INSTANTÁNEA PARA ENVIAR ENLACES FRAUDULENTOS.
- **EJEMPLO:** RECIBIR UN SMS QUE DICE: "PAQUETERÍA DHL: SU PAQUETE NO PUDO SER ENTREGADO POR FALTA DE NÚMERO DE CASA. ACTUALICE SUS DATOS AQUÍ: [ENLACE_FALSO]".

- **DESCRIPCIÓN:** PHISHING REALIZADO A TRAVÉS DE LLAMADAS TELEFÓNICAS DE VOZ. LOS ATACANTES SUELEN CLONAR LA VOZ, USAR GRABACIONES PROFESIONALES O EMPLEAR TÉCNICAS DE PERSUASIÓN VERBAL PARA HACERSE PASAR POR AGENTES DE SOPORTE O DEL BANCO.
- **EJEMPLO:** UNA LLAMADA DE UN SUPUESTO AGENTE DE FRAUDES DE TU BANCO QUE TE DICE QUE HAY CARGOS SOSPECHOSOS EN TU TARJETA Y TE PIDE DICTARLE EL CÓDIGO SMS DE VERIFICACIÓN QUE ACABA DE LLEGAR A TU TELÉFONO PARA "CANCELAR" EL CARGO.



Vishing

Baiting (Señuelo)

y

- **DESCRIPCIÓN:** CONSISTE EN OFRECER UN BIEN MATERIAL O DIGITAL SUMAMENTE ATRACTIVO A LA VÍCTIMA PARA DESPERTAR SU CURIOSIDAD O CODICIA, EMPUJÁNDOLA A CAER EN UNA TRAMPA QUE INFECTARÁ SU EQUIPO.

- **EJEMPLO:** DEJAR CAER A PROPÓSITO UNA MEMORIA USB EN EL ESTACIONAMIENTO DE UNA EMPRESA CON UNA ETIQUETA IMPRESA QUE DICE "SUELDOS Y BONOS DE DIRECTIVOS 2026". UN EMPLEADO CURIOSO LA RECOGE Y LA CONECTA A SU COMPUTADORA DE LA OFICINA.



Pretexting

- **DESCRIPCIÓN:** EL ATACANTE CREA UN ESCENARIO O UNA HISTORIA FICTICIA COMPLEJA (UN PRETEXTU) MUY ELABORADA PARA GANARSE LA CONFIANZA DE LA VÍCTIMA, ASUMIENDO UNA IDENTIDAD CON AUTORIDAD LEGÍTIMA.

- **EJEMPLO:** UN ATACANTE LLAMA A UN EMPLEADO FINGIENDO SER DEL DEPARTAMENTO DE AUDITORÍA INTERNA EXTERNA, MENCIONANDO DATOS REALES OBTENIDOS PREVIAMENTE, PARA SOLICITAR QUE LE CONFIRME CIERTOS ACCESOS CORPORATIVOS COMO PARTE DE UNA "REVISIÓN DE RUTINA".



- **DESCRIPCIÓN:** SIGNIFICA "ALGO A CAMBIO DE ALGO". EL ATACANTE OFRECE UN SERVICIO TÉCNICO, UN BENEFICIO O UN REGALO A LA VÍCTIMA A CAMBIO DE QUE ESTA REALICE UNA ACCIÓN ESPECÍFICA O COMPARTA SUS CREDENCIALES.
- **EJEMPLO:** LLAMAR A EMPLEADOS AL AZAR FINGIENDO SER DEL SOPORTE TÉCNICO DE TI DICIENDO: "ESTAMOS SOLUCIONANDO UN PROBLEMA DE LENTITUD EN SU RED, SOLO NECESITO QUE ME PROPORCIONE SU CONTRASEÑA PARA APLICAR EL PARCHÉ RÁPIDO".

Tailgating / Piggybacking (Colarse)

- **DESCRIPCIÓN:** TÉCNICA FÍSICA DE INGENIERÍA SOCIAL DONDE UN ATACANTE SIN AUTORIZACIÓN SIGUE DE CERCA A UN EMPLEADO LEGÍTIMO QUE TIENE UNA TARJETA DE ACCESO PARA COLARSE A UN EDIFICIO RESTRINGIDO ANTES DE QUE LA PUERTA SE CIERRE.
- **EJEMPLO:** EL ATACANTE CAMINA HACIA LA PUERTA DE LOS SERVIDORES CARGANDO CAJAS PESADAS EN LAS MANOS; EL EMPLEADO CON TARJETA, POR CORTESÍA, LE SOSTIENE LA PUERTA ABIERTA PERMITIÉNDOLE EL ACCESO SIN VALIDAR SU IDENTIDAD.



Quid Pro Quo





Catfishing / Romances falsos

- **DESCRIPCIÓN:** OCURRE CUANDO UN ATACANTE PIRATEA O SUPLANTA CON TOTAL PRECISIÓN LA CUENTA DE CORREO ELECTRÓNICO CORPORATIVA DE UN EJECUTIVO O PROVEEDOR CLAVE PARA ENGAÑAR A LOS EMPLEADOS Y HACER QUE REALICEN TRANSFERENCIAS DE FONDOS MASIVAS.
- **EJEMPLO:** LOS HACKERS INTERCEPTAN CORREOS REALES ENTRE UN PROVEEDOR Y UNA EMPRESA, CLONAN EL DOMINIO DEL PROVEEDOR Y ENVÍAN UN CORREO DICIENDO: "HEMOS CAMBIADO DE BANCO, POR FAVOR DEPOSITE EL PAGO DE LAS FACTURAS DE ESTE MES EN ESTA NUEVA CUENTA CORPORATIVA".

- **DESCRIPCIÓN:** CREACIÓN DE UN PERFIL DIGITAL COMPLETAMENTE FALSO EN REDES SOCIALES O APLICACIONES DE CITAS. EL ATACANTE INVIERTE SEMANAS O MESES CONSTRUYENDO UNA RELACIÓN AFECTIVA CON LA VÍCTIMA PARA EVENTUALMENTE EXIGIRLE DINERO O FAVORES.
- **EJEMPLO:** UN PERFIL FALSO QUE ASEGURA SER UN MILITAR EXTRANJERO EN UNA MISIÓN HUMANITARIA ENAMORA A UNA PERSONA POR INTERNET Y, TRAS GANAR SU CONFIANZA, LE PIDE DINERO URGENTE PARA COSTEAR UN PASAJE DE AVIÓN O UN TRATAMIENTO MÉDICO DE EMERGENCIA.

Business Email Compromise (BEC)



Scareware

- **DESCRIPCIÓN: SOFTWARE MALICIOSO O TÁCTICA WEB QUE UTILIZA ALERTAS DE SEGURIDAD FALSAS IMPACTANTES Y ATERRADORAS PARA HACER CREER AL USUARIO QUE SU SISTEMA ESTÁ INFECTADO O QUE HA COMETIDO UN DELITO, OBLIGÁNDOLO A COMPRAR SOFTWARE FALSO O DAR DATOS BANCARIOS.**
- **EJEMPLO: MIENTRAS NAVEGAS EN UNA WEB, APARECE UNA VENTANA EMERGENTE QUE SIMULA SER DE WINDOWS CON LUCES PARPADEANTES QUE DICE: "/ALERTA/ SE DETECTARON 45 VIRUS ESPÍAS EN SU SISTEMA. DESCARGUE NUESTRO ANTIVIRUS GRATUITO YA O SU COMPUTADORA QUEDARÁ INUTILIZABLE EN 10 SEGUNDOS".**



THANK YOU FOR WATCHING MY PRESENTATION



CONCLUSIÓN

- **EL CÓDIGO Y LA MENTE: LA CIBERSEGURIDAD NO SOLO SE ESCRIBE EN LÍNEAS DE CÓDIGO SEGURAS EN PYTHON, TAMBIÉN SE PRACTICA DESCONFIANDO DE LOS VECTORES DE ATAQUE EN EL DÍA A DÍA.**
- **LA REGLA DE ORO: EN UN MUNDO INTERCONECTADO, EL ESLABÓN MÁS DÉBIL SIEMPRE SERÁ EL FACTOR HUMANO SI NO SE MANTIENE EDUCADO Y ALERTA.**

FIN :D